Vulnerability Assessment & Penetration Test Report

AI-assisted, evidence-backed assessment of an authorised lab target

Assessment ID: 20261103-230206
Scope: Local lab
Authorisation reference: HACKATHON-LAB-001
Targets: 127.0.0.1
Started: 2026-11-03 23:02:06 UTC
Completed: 2026-11-03 23:02:07 UTC
Agent model: rules-only (no LLM configured)
Classification: Confidential - client delivery

Reading guide: statements marked OBSERVED come directly from tool output and cite an evidence ID (E-xxxx). Statements marked AI INFERENCE are reasoning about impact, are labelled with the model or rules engine that produced them, and cite the evidence they rest on. Severity, CVSS and CVE data are reproduced from tool output; risk scores are computed by deterministic code from those inputs and the factors shown.

1. Executive Summary

Assessment scope

Authorised targets: 127.0.0.0/30. Exclusions: 127.0.0.3. Active scanning was permitted; offensive validation was permitted only with per-action human approval. All testing stayed inside the organiser-authorised lab scope enforced by a deny-by-default guard.

Overall assessment (generated by the deterministic rules engine)

The assessment produced 12 consolidated findings (4 high, 1 medium, 4 low, 3 info by tool-reported severity); 12 confirmed by direct observation. The highest-priority item is F-003 "Telnet service exposed (cleartext remote administration)" [P1]. 4 limitation(s) affected coverage and are listed in the report.

Findings: 12 total - 12 confirmed, 0 suspected, 0 likely false positive. Evidence items: 24. Tool runs: 4.

Top priorities

F-003 [P1] Telnet service exposed (cleartext remote administration) - HIGH, high confidence
F-008 [P1] Login form served over unencrypted HTTP - HIGH, high confidence
F-011 [P1] Exposed .git repository metadata - HIGH, high confidence

2. Assessment Methodology

The assessment followed the NIST SP 800-115 technical testing lifecycle (planning, discovery, attack/validation, reporting) with the agent proposing each step, a deterministic scope guard approving or refusing it, and a human analyst approving scans and any active validation. Findings were described using CVE, CVSS and CWE identifiers where tools reported them, and OWASP Top 10 categories for web issues. Use of these references does not establish formal compliance with any standard.

Rules of engagement

- Authorisation reference: HACKATHON-LAB-001
- Targets: 127.0.0.0/30; exclusions: 127.0.0.3
- Lab-only addressing enforced: yes (loopback/private ranges only)
- Port allow-list: any; rate limit: 0 requests/second (0 = unlimited)
- Tools permitted: all registered tools
- Exploitation: never autonomous. Validation uses non-exploiting module checks only and requires explicit analyst approval, recorded in the audit trail.
- Data handling: raw outputs and the audit log are stored with owner-only permissions; secrets observed in output are redacted in evidence.

Assets tested

Asset	Service	Product / version	Observed by	Evidence
127.0.0.1:2121/tcp	ftp		portscan	E-0001
127.0.0.1:2323/tcp	telnet		portscan	E-0002
127.0.0.1:8000/tcp	http	LabSPA	portscan	E-0003
127.0.0.1:8008/tcp	http	LabLegacy/0.9	portscan	E-0004
127.0.0.1:8081/tcp	http	LabHTTPd/1.0	portscan	E-0005
127.0.0.1:8000/tcp	http	LabSPA	webcheck	E-0009
127.0.0.1:8008/tcp	http	LabLegacy/0.9	webcheck	E-0010
127.0.0.1:8081/tcp	http	LabHTTPd/1.0	webcheck	E-0015

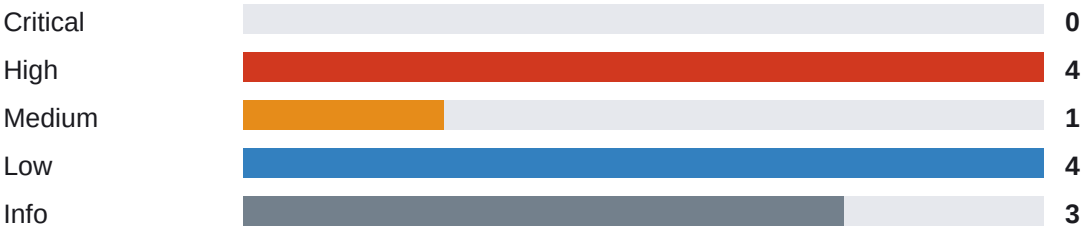
Tool execution summary

Step	Tool (mode)	Target	Outcome	Time	Planned
S-01	portscan (live)	127.0.0.1	done: 46 ports probed, 5 open	703ms	by rules
S-02	webcheck (live)	http://127.0.0.1:8000	done: http://127.0.0.1:8000 -> HTTP 200, 0 issues	2ms	by rules
S-03	webcheck (live)	http://127.0.0.1:8008	done: http://127.0.0.1:8008 -> HTTP 200, 4 issues	7ms	by rules
S-04	webcheck (live)	http://127.0.0.1:8081	done: http://127.0.0.1:8081 -> HTTP 200, 9 issues	2ms	by rules

Why each step was chosen

S-01 portscan: No services are known for 127.0.0.1. Nmap is unavailable (nmap binary not found in PATH), so the built-in connect scan with banner grab does reconnaissance instead.
S-02 webcheck: Port 8000 on 127.0.0.1 answers HTTP (server: LabSPA), so web configuration checks are warranted.
S-03 webcheck: Port 8008 on 127.0.0.1 answers HTTP (server: LabLegacy/0.9), so web configuration checks are warranted.
S-04 webcheck: Port 8081 on 127.0.0.1 answers HTTP (server: LabHTTPd/1.0), so web configuration checks are warranted.

3. Severity Distribution and Prioritised Findings



Severity is as reported by the source tool(s) (highest across merged reports). Priority P1-P4 comes from the computed risk score, which combines CVSS (or nominal severity), exposure, tool-reported exploit availability, analyst-set asset criticality and confidence.

ID	Finding	Assets	Severity	CVSS	Risk	Status
F-003	Telnet service exposed (cleartext remote administrati…	127.0.0.1:2323	HIGH	n/r	87 P1	confirmed
F-008	Login form served over unencrypted HTTP	127.0.0.1:8081	HIGH	n/r	87 P1	confirmed
F-011	Exposed .git repository metadata	127.0.0.1:8081	HIGH	n/r	87 P1	confirmed
F-010	Exposed environment file (.env)	127.0.0.1:8081	HIGH	n/r	87 P1	confirmed
F-002	FTP service exposed (cleartext file transfer)	127.0.0.1:2121	MEDIUM	n/r	60 P2	confirmed
F-004	Missing Content-Security-Policy header	127.0.0.1:8008, 127.0.0.1:8081	LOW	n/r	27 P3	confirmed
F-006	Missing clickjacking protection (X-Frame-Options / fr…	127.0.0.1:8008, 127.0.0.1:8081	LOW	n/r	27 P3	confirmed
F-005	Missing X-Content-Type-Options header	127.0.0.1:8008, 127.0.0.1:8081	LOW	n/r	27 P3	confirmed
F-009	Cookie set without HttpOnly flag	127.0.0.1:8081	LOW	n/r	27 P3	confirmed
F-001	Service banner discloses software details (ftp)	127.0.0.1:2121	INFO	n/r	0 P4	confirmed

F-007	Web server discloses software/version in Server header	127.0.0.1:8008, 127.0.0.1:8081	INFO	n/r	0 P4	confirmed
F-012	X-Powered-By header discloses technology stack	127.0.0.1:8081	INFO	n/r	0 P4	confirmed

4. Detailed Vulnerability Findings

HIGH

F-003 Telnet service exposed (cleartext remote administration)

Affected assets (OBSERVED):

127.0.0.1:2323 telnet - reported by portscan; evidence E-0008

Severity: HIGH CVSS: not reported by any tool

CVE: - CWE: CWE-319 OWASP: A02:2021 Cryptographic Failures

Status: confirmed Confidence: high (90%) Validation: not_validated Basis: direct

Description (OBSERVED / tool-reported):

A Telnet service accepted a TCP connection. Telnet transmits credentials and session data without encryption.

Supporting evidence:

E-0008 tool=portscan asset=127.0.0.1:2323 time=2026-11-03 23:02:07 UTC

raw reference: raw/S-01-portscan.txt — line 24

```
127.0.0.1:2323/tcp open service=telnet banner="Lab login:"
```

Risk score computation:

- base = 8.00: no CVSS reported; nominal value for tool-reported severity "high"
- exposure = 1.00: service reached over the network by our own probe
- exploitability = 1.00: no exploit information reported by any tool
- asset_impact = 1.15: analyst-set criticality "high" for 127.0.0.1
- confidence_weight = 0.95: 0.5 + 0.5 x confidence 0.90

=> risk 87.4 / 100, priority P1

AI INFERENCE (generated by the deterministic rules engine; cites E-0008):

Inference: credentials or session data sent over this channel could be read by anyone able to observe network traffic between the client and the service; the finding itself (service reachable / form served over HTTP) is observed, the interception risk is not tested.

HIGH

F-008 Login form served over unencrypted HTTP

Affected assets (OBSERVED):

127.0.0.1:8081 http - reported by webcheck; evidence E-0022

Severity: HIGH CVSS: not reported by any tool

CVE: - CWE: CWE-319 OWASP: A02:2021 Cryptographic Failures

Status: confirmed Confidence: high (90%) Validation: not_validated Basis: direct

Description (OBSERVED / tool-reported):

A page containing a password field is delivered over plain HTTP, so credentials can be intercepted on the network.

Supporting evidence:

E-0022 tool=webcheck asset=127.0.0.1:8081 time=2026-11-03 23:02:07 UTC

raw reference: raw/S-04-webcheck.txt — line 14

```
GET http://127.0.0.1:8081 -> 200; HTML contains an input of type=password
```

Risk score computation:

- base = 8.00: no CVSS reported; nominal value for tool-reported severity "high"
- exposure = 1.00: service reached over the network by our own probe
- exploitability = 1.00: no exploit information reported by any tool
- asset_impact = 1.15: analyst-set criticality "high" for 127.0.0.1
- confidence_weight = 0.95: 0.5 + 0.5 x confidence 0.90

=> risk 87.4 / 100, priority P1

AI INFERENCE (generated by the deterministic rules engine; cites E-0022):

Inference: credentials or session data sent over this channel could be read by anyone able to observe network traffic between the client and the service; the finding itself (service reachable / form served over HTTP) is observed, the interception risk is not tested.

HIGH

F-011 Exposed .git repository metadata

Affected assets (OBSERVED):

127.0.0.1:8081 http - reported by webcheck; evidence E-0023

Severity: HIGH CVSS: not reported by any tool

CVE: - CWE: CWE-527 OWASP: A05:2021 Security Misconfiguration

Status: confirmed Confidence: high (90%) Validation: not_validated Basis: direct

Description (OBSERVED / tool-reported):

The /.git/ directory is reachable; source code and secrets may be reconstructable.

Supporting evidence:

E-0023 tool=webcheck asset=127.0.0.1:8081 time=2026-11-03 23:02:07 UTC

raw reference: raw/S-04-webcheck.txt — line 16

```
GET /.git/HEAD -> 200; ref: refs/heads/main
```

Risk score computation:

- base = 8.00: no CVSS reported; nominal value for tool-reported severity "high"
- exposure = 1.00: service reached over the network by our own probe
- exploitability = 1.00: no exploit information reported by any tool
- asset_impact = 1.15: analyst-set criticality "high" for 127.0.0.1
- confidence_weight = 0.95: 0.5 + 0.5 x confidence 0.90

=> risk 87.4 / 100, priority P1

AI INFERENCE (generated by the deterministic rules engine; cites E-0023):

Inference: exposed repository or environment data may allow an attacker to recover source code, credentials or API keys; contents were not downloaded or tested beyond confirming the file's signature.

HIGH

F-010 Exposed environment file (.env)

Affected assets (OBSERVED):

127.0.0.1:8081 http - reported by webcheck; evidence E-0024

Severity: HIGH CVSS: not reported by any tool

CVE: - CWE: CWE-538 OWASP: A05:2021 Security Misconfiguration

Status: confirmed Confidence: high (90%) Validation: not_validated Basis: direct

Description (OBSERVED / tool-reported):

An environment file is downloadable and typically holds credentials and API keys.

Supporting evidence:

E-0024 tool=webcheck asset=127.0.0.1:8081 time=2026-11-03 23:02:07 UTC

raw reference: raw/S-04-webcheck.txt — line 17

```
GET /.env -> 200; keys present (values redacted): DB_PASSWORD, API_KEY
```

Risk score computation:

- base = 8.00: no CVSS reported; nominal value for tool-reported severity "high"
- exposure = 1.00: service reached over the network by our own probe
- exploitability = 1.00: no exploit information reported by any tool
- asset_impact = 1.15: analyst-set criticality "high" for 127.0.0.1
- confidence_weight = 0.95: 0.5 + 0.5 x confidence 0.90

=> risk 87.4 / 100, priority P1

AI INFERENCE (generated by the deterministic rules engine; cites E-0024):

Inference: exposed repository or environment data may allow an attacker to recover source code, credentials or API keys; contents were not downloaded or tested beyond confirming the file's signature.

MEDIUM

F-002 FTP service exposed (cleartext file transfer)

Affected assets (OBSERVED):

127.0.0.1:2121 ftp - reported by portscan; evidence E-0006

Severity: MEDIUM CVSS: not reported by any tool

CVE: - CWE: CWE-319 OWASP: A02:2021 Cryptographic Failures

Status: confirmed Confidence: high (90%) Validation: not_validated Basis: direct

Description (OBSERVED / tool-reported):

An FTP service accepted a TCP connection. Plain FTP transmits credentials and data without encryption.

Supporting evidence:

E-0006 tool=portscan asset=127.0.0.1:2121 time=2026-11-03 23:02:07 UTC

raw reference: raw/S-01-portscan.txt — line 22

```
127.0.0.1:2121/tcp open service=ftp banner="220 LabFTP ready (anonymous allowed)"
```

Risk score computation:

- base = 5.50: no CVSS reported; nominal value for tool-reported severity "medium"
- exposure = 1.00: service reached over the network by our own probe
- exploitability = 1.00: no exploit information reported by any tool
- asset_impact = 1.15: analyst-set criticality "high" for 127.0.0.1
- confidence_weight = 0.95: 0.5 + 0.5 x confidence 0.90

=> risk 60.1 / 100, priority P2

AI INFERENCE (generated by the deterministic rules engine; cites E-0006):

Inference: credentials or session data sent over this channel could be read by anyone able to observe network traffic between the client and the service; the finding itself (service reachable / form served over HTTP) is observed, the interception risk is not tested.

LOW

F-004 Missing Content-Security-Policy header

Affected assets (OBSERVED):

127.0.0.1:8008 http - reported by webcheck; evidence E-0011

127.0.0.1:8081 http - reported by webcheck; evidence E-0016

Severity: LOW CVSS: not reported by any tool

CVE: - CWE: CWE-693 OWASP: A05:2021 Security Misconfiguration

Status: confirmed Confidence: high (90%) Validation: not_validated Basis: direct

Description (OBSERVED / tool-reported):

The response has no Content-Security-Policy, which weakens defence-in-depth against cross-site scripting and content injection.

Supporting evidence:

E-0011 tool=webcheck asset=127.0.0.1:8008 time=2026-11-03 23:02:07 UTC

raw reference: raw/S-03-webcheck.txt — line 8

```
GET http://127.0.0.1:8008 -> 200; response headers contain no "content-security-policy" header
```

E-0016 tool=webcheck asset=127.0.0.1:8081 time=2026-11-03 23:02:07 UTC

raw reference: raw/S-04-webcheck.txt — line 10

```
GET http://127.0.0.1:8081 -> 200; response headers contain no "content-security-policy" header
```

Risk score computation:

- base = 2.50: no CVSS reported; nominal value for tool-reported severity "low"
- exposure = 1.00: service reached over the network by our own probe
- exploitability = 1.00: no exploit information reported by any tool
- asset_impact = 1.15: analyst-set criticality "high" for 127.0.0.1
- confidence_weight = 0.95: 0.5 + 0.5 x confidence 0.90

=> risk 27.3 / 100, priority P3

AI INFERENCE (generated by the deterministic rules engine; cites E-0011):

Inference: on its own this is a hardening gap, not an exploitable flaw; it increases impact only if another weakness (such as XSS or framing) is present.

LOW

F-006 Missing clickjacking protection (X-Frame-Options / frame-ancestors)

Affected assets (OBSERVED):

127.0.0.1:8008 http - reported by webcheck; evidence E-0012

127.0.0.1:8081 http - reported by webcheck; evidence E-0017

Severity: LOW CVSS: not reported by any tool
CVE: - CWE: CWE-1021 OWASP: A05:2021 Security Misconfiguration
Status: confirmed Confidence: high (90%) Validation: not_validated Basis: direct

Description (OBSERVED / tool-reported):

Neither X-Frame-Options nor a CSP frame-ancestors directive is present, so the page can be framed by other origins.

Supporting evidence:

E-0012 tool=webcheck asset=127.0.0.1:8008 time=2026-11-03 23:02:07 UTC

raw reference: raw/S-03-webcheck.txt — line 9

```
GET http://127.0.0.1:8008 -> 200; response headers contain no "x-frame-options" header
```

E-0017 tool=webcheck asset=127.0.0.1:8081 time=2026-11-03 23:02:07 UTC

raw reference: raw/S-04-webcheck.txt — line 11

```
GET http://127.0.0.1:8081 -> 200; response headers contain no "x-frame-options" header
```

Risk score computation:

- base = 2.50: no CVSS reported; nominal value for tool-reported severity "low"
- exposure = 1.00: service reached over the network by our own probe
- exploitability = 1.00: no exploit information reported by any tool
- asset_impact = 1.15: analyst-set criticality "high" for 127.0.0.1
- confidence_weight = 0.95: 0.5 + 0.5 x confidence 0.90

=> risk 27.3 / 100, priority P3

AI INFERENCE (generated by the deterministic rules engine; cites E-0012):

Inference: on its own this is a hardening gap, not an exploitable flaw; it increases impact only if another weakness (such as XSS or framing) is present.

LOW

F-005 Missing X-Content-Type-Options header

Affected assets (OBSERVED):

127.0.0.1:8008 http - reported by webcheck; evidence E-0013
127.0.0.1:8081 http - reported by webcheck; evidence E-0018

Severity: LOW CVSS: not reported by any tool
CVE: - CWE: CWE-693 OWASP: A05:2021 Security Misconfiguration
Status: confirmed Confidence: high (90%) Validation: not_validated Basis: direct

Description (OBSERVED / tool-reported):

Responses lack 'X-Content-Type-Options: nosniff', allowing MIME sniffing in some browsers.

Supporting evidence:

E-0013 tool=webcheck asset=127.0.0.1:8008 time=2026-11-03 23:02:07 UTC

raw reference: raw/S-03-webcheck.txt — line 10

```
GET http://127.0.0.1:8008 -> 200; response headers contain no "x-content-type-options" header
```

E-0018 tool=webcheck asset=127.0.0.1:8081 time=2026-11-03 23:02:07 UTC

raw reference: raw/S-04-webcheck.txt — line 12

```
GET http://127.0.0.1:8081 -> 200; response headers contain no "x-content-type-options" header
```

Risk score computation:

- base = 2.50: no CVSS reported; nominal value for tool-reported severity "low"
- exposure = 1.00: service reached over the network by our own probe
- exploitability = 1.00: no exploit information reported by any tool
- asset_impact = 1.15: analyst-set criticality "high" for 127.0.0.1
- confidence_weight = 0.95: 0.5 + 0.5 x confidence 0.90

=> risk 27.3 / 100, priority P3

AI INFERENCE (generated by the deterministic rules engine; cites E-0013):

Inference: on its own this is a hardening gap, not an exploitable flaw; it increases impact only if another weakness (such as XSS or framing) is present.

LOW

F-009 Cookie set without HttpOnly flag

Affected assets (OBSERVED):

127.0.0.1:8081 http - reported by webcheck; evidence E-0021

Severity: LOW CVSS: not reported by any tool

CVE: - CWE: CWE-1004 OWASP: A05:2021 Security Misconfiguration
Status: confirmed Confidence: high (90%) Validation: not_validated Basis: direct
Description (OBSERVED / tool-reported):
A cookie is issued without HttpOnly, so client-side script can read it if XSS exists.
Supporting evidence:
E-0021 tool=webcheck asset=127.0.0.1:8081 time=2026-11-03 23:02:07 UTC
raw reference: raw/S-04-webcheck.txt — line 13 (cookie session)

```
Set-Cookie: session=<redacted>;
```

Risk score computation:
- base = 2.50: no CVSS reported; nominal value for tool-reported severity "low"
- exposure = 1.00: service reached over the network by our own probe
- exploitability = 1.00: no exploit information reported by any tool
- asset_impact = 1.15: analyst-set criticality "high" for 127.0.0.1
- confidence_weight = 0.95: 0.5 + 0.5 x confidence 0.90

=> risk 27.3 / 100, priority P3

INFO

F-001 Service banner discloses software details (ftp)

Affected assets (OBSERVED):
127.0.0.1:2121 ftp - reported by portscan; evidence E-0007
Severity: INFO CVSS: not reported by any tool
CVE: - CWE: CWE-200 OWASP: A05:2021 Security Misconfiguration
Status: confirmed Confidence: high (90%) Validation: not_validated Basis: direct
Description (OBSERVED / tool-reported):
The service announces product/version information to unauthenticated clients, aiding attacker reconnaissance.
Supporting evidence:
E-0007 tool=portscan asset=127.0.0.1:2121 time=2026-11-03 23:02:07 UTC
raw reference: raw/S-01-portscan.txt — line 22

```
127.0.0.1:2121/tcp open service=ftp banner="220 LabFTP ready (anonymous allowed)"
```

Risk score computation:
- base = 0.00: no CVSS reported; nominal value for tool-reported severity "info"
- exposure = 1.00: service reached over the network by our own probe
- exploitability = 1.00: no exploit information reported by any tool
- asset_impact = 1.15: analyst-set criticality "high" for 127.0.0.1
- confidence_weight = 0.95: 0.5 + 0.5 x confidence 0.90

=> risk 0.0 / 100, priority P4
AI INFERENCE (generated by the deterministic rules engine; cites E-0007):
Inference: disclosed version strings may help an attacker select version-specific exploits; no vulnerability is claimed from the banner alone.

INFO

F-007 Web server discloses software/version in Server header

Affected assets (OBSERVED):
127.0.0.1:8008 http - reported by webcheck; evidence E-0014
127.0.0.1:8081 http - reported by webcheck; evidence E-0019
Severity: INFO CVSS: not reported by any tool
CVE: - CWE: CWE-200 OWASP: A05:2021 Security Misconfiguration
Status: confirmed Confidence: high (90%) Validation: not_validated Basis: direct
Description (OBSERVED / tool-reported):
The Server header reveals product and version, helping attackers choose targeted exploits.
Supporting evidence:
E-0014 tool=webcheck asset=127.0.0.1:8008 time=2026-11-03 23:02:07 UTC
raw reference: raw/S-03-webcheck.txt — line 6

```
Server: LabLegacy/0.9
```

E-0019 tool=webcheck asset=127.0.0.1:8081 time=2026-11-03 23:02:07 UTC
raw reference: raw/S-04-webcheck.txt — line 3

```
Server: LabHTTPd/1.0
```

Risk score computation:

- base = 0.00: no CVSS reported; nominal value for tool-reported severity "info"
- exposure = 1.00: service reached over the network by our own probe
- exploitability = 1.00: no exploit information reported by any tool
- asset_impact = 1.15: analyst-set criticality "high" for 127.0.0.1
- confidence_weight = 0.95: 0.5 + 0.5 x confidence 0.90

=> risk 0.0 / 100, priority P4

AI INFERENCE (generated by the deterministic rules engine; cites E-0014):

Inference: disclosed version strings may help an attacker select version-specific exploits; no vulnerability is claimed from the banner alone.

INFO

F-012 X-Powered-By header discloses technology stack

Affected assets (OBSERVED):

127.0.0.1:8081 http - reported by webcheck; evidence E-0020

Severity: INFO CVSS: not reported by any tool

CVE: - CWE: CWE-200 OWASP: A05:2021 Security Misconfiguration

Status: confirmed Confidence: high (90%) Validation: not_validated Basis: direct

Description (OBSERVED / tool-reported):

The X-Powered-By header reveals the application framework or runtime.

Supporting evidence:

E-0020 tool=webcheck asset=127.0.0.1:8081 time=2026-11-03 23:02:07 UTC

raw reference: raw/S-04-webcheck.txt — line 5

```
X-Powered-By: LabFramework/0.1
```

Risk score computation:

- base = 0.00: no CVSS reported; nominal value for tool-reported severity "info"
- exposure = 1.00: service reached over the network by our own probe
- exploitability = 1.00: no exploit information reported by any tool
- asset_impact = 1.15: analyst-set criticality "high" for 127.0.0.1
- confidence_weight = 0.95: 0.5 + 0.5 x confidence 0.90

=> risk 0.0 / 100, priority P4

AI INFERENCE (generated by the deterministic rules engine; cites E-0020):

Inference: disclosed version strings may help an attacker select version-specific exploits; no vulnerability is claimed from the banner alone.

5. Impact and Remediation

F-003 Telnet service exposed (cleartext remote administration) [P1]

Technical and business impact:

Inference: credentials or session data sent over this channel could be read by anyone able to observe network traffic between the client and the service; the finding itself (service reachable / form served over HTTP) is observed, the interception risk is not tested. (AI inference; see Section 4.)

Recommended remediation:

Disable Telnet and use SSH with key-based authentication. Restrict management ports to an admin network.

References: https://cwe.mitre.org/data/definitions/319.html

F-008 Login form served over unencrypted HTTP [P1]

Technical and business impact:

Inference: credentials or session data sent over this channel could be read by anyone able to observe network traffic between the client and the service; the finding itself (service reachable / form served over HTTP) is observed, the interception risk is not tested. (AI inference; see Section 4.)

Recommended remediation:

Serve all authenticated pages over HTTPS and redirect HTTP to HTTPS.

F-011 Exposed .git repository metadata [P1]

Technical and business impact:

Inference: exposed repository or environment data may allow an attacker to recover source code, credentials or API keys; contents were not downloaded or tested beyond confirming the file's signature. (AI inference; see Section 4.)

Recommended remediation:

Block access to /.git/ at the web server and remove VCS metadata from deployed content.

F-010 Exposed environment file (.env) [P1]

Technical and business impact:

Inference: exposed repository or environment data may allow an attacker to recover source code, credentials or API keys; contents were not downloaded or tested beyond confirming the file's signature. (AI inference; see Section 4.)

Recommended remediation:

Remove .env from the web root and rotate every secret it contained.

F-002 FTP service exposed (cleartext file transfer) [P2]

Technical and business impact:

Inference: credentials or session data sent over this channel could be read by anyone able to observe network traffic between the client and the service; the finding itself (service reachable / form served over HTTP) is observed, the interception risk is not tested. (AI inference; see Section 4.)

Recommended remediation:

Replace FTP with SFTP or FTPS and disable anonymous access unless explicitly required.

References: https://cwe.mitre.org/data/definitions/319.html

F-004 Missing Content-Security-Policy header [P3]

Technical and business impact:

Inference: on its own this is a hardening gap, not an exploitable flaw; it increases impact only if another weakness (such as XSS or framing) is present. (AI inference; see Section 4.)

Recommended remediation:

Define a restrictive Content-Security-Policy (default-src 'self') and tighten it iteratively.

References: https://owasp.org/www-project-secure-headers/

F-006 Missing clickjacking protection (X-Frame-Options / frame-ancestors) [P3]

Technical and business impact:

Inference: on its own this is a hardening gap, not an exploitable flaw; it increases impact only if another weakness (such as XSS or framing) is present. (AI inference; see Section 4.)

Recommended remediation:

Send 'X-Frame-Options: DENY' (or SAMEORIGIN) or a CSP 'frame-ancestors' directive.

References: https://owasp.org/www-project-secure-headers/

F-005 Missing X-Content-Type-Options header [P3]

Technical and business impact:

Inference: on its own this is a hardening gap, not an exploitable flaw; it increases impact only if another weakness (such as XSS or framing) is present. (AI inference; see Section 4.)

Recommended remediation:

Send 'X-Content-Type-Options: nosniff' on all responses.

References: https://owasp.org/www-project-secure-headers/

F-009 Cookie set without HttpOnly flag [P3]

Technical and business impact:

No impact inference was produced; see the observed description in Section 4.

Recommended remediation:

Set HttpOnly on session and authentication cookies.

F-001 Service banner discloses software details (ftp) [P4]

Technical and business impact:

Inference: disclosed version strings may help an attacker select version-specific exploits; no vulnerability is claimed from the banner alone. (AI inference; see Section 4.)

Recommended remediation:

Suppress or genericise service banners where the product allows it.

F-007 Web server discloses software/version in Server header [P4]

Technical and business impact:

Inference: disclosed version strings may help an attacker select version-specific exploits; no vulnerability is claimed from the banner alone. (AI inference; see Section 4.)

Recommended remediation:

Remove or genericise the Server header (e.g. ServerTokens Prod / server_tokens off).

F-012 X-Powered-By header discloses technology stack [P4]

Technical and business impact:

Inference: disclosed version strings may help an attacker select version-specific exploits; no vulnerability is claimed from the banner alone. (AI inference; see Section 4.)

Recommended remediation:

Disable the X-Powered-By header in the framework or reverse proxy.

6. Assessment Limitations

- Testing covered only the targets, ports and tools in the registered scope; absence of findings is not proof of absence of vulnerabilities.
- Built-in checks are read-only and shallow by design (HTTP configuration, banners, exposure); they do not test authentication, business logic or input handling.
- Findings imported from commercial tools (Nessus, Greenbone, Burp) reflect the exports supplied and were not re-run by this agent.
- Version-based findings are suspected, not confirmed, until validated; back-ported patches can make them false positives.
- Confidence values are calibrated heuristics (basis of detection and corroboration across tools), not statistical probabilities.
- LLM output is limited to plans and impact reasoning; it cannot set severity, CVSS, CVE data or risk scores, and ungrounded statements are rejected by code.

Assumptions

- The targets are organiser-provided lab systems and were not modified during the test.
- Tool outputs were taken as produced; timestamps are in UTC from the agent host clock.

Scan failures, skipped and blocked steps

- Target 8.8.8.8 named in the request was REFUSED by the scope guard (8.8.8.8 is outside the authorised scope); no traffic was sent to it.
- nmap was not available (nmap binary not found in PATH); its coverage was not performed.
- nikto was not available (nikto binary not found in PATH); its coverage was not performed.
- zap was not available (ZAP daemon not reachable at http://127.0.0.1:8090 (start `zap.sh -daemon -port 8090` and set ZAP_URL / ZAP_API_KEY)); its coverage was not performed.

Human approvals

No active validation was requested; no offensive validation was performed.

Plan approvals:

- 2026-11-03 23:02:06 UTC analyst:demo-analyst approved S-01 (portscan on 127.0.0.1)
- 2026-11-03 23:02:07 UTC analyst:demo-analyst approved S-02 (webcheck on http://127.0.0.1:8000)
- 2026-11-03 23:02:07 UTC analyst:demo-analyst approved S-03 (webcheck on http://127.0.0.1:8008)
- 2026-11-03 23:02:07 UTC analyst:demo-analyst approved S-04 (webcheck on http://127.0.0.1:8081)

Assessment timestamps

Started 2026-11-03 23:02:06 UTC; analysis completed 2026-11-03 23:02:07 UTC; report generated 2026-11-03 23:02:08 UTC.

Appendix A. Integration status

Tool	Status	Available here	Limitations
Nmap	Live	no: nmap binary not found in PATH	Requires the nmap binary on PATH; script (vulners) output is a version match only.
Nessus	Import-only	yes	No live API integration; import only. Nessus is commercial (Essentials is capped at 16 hosts per Tenable docs): the analyst supplies a .nessus export from their own licence.
OpenVAS / Greenbone	Import-only	yes	No live GMP session yet (planned). Import accepts gvm-cli / web UI XML reports.
Nikto	Live	no: nikto binary not found in PATH	Requires the nikto binary on PATH. Nikto does not rate severity; findings carry a nominal 'low'.
OWASP ZAP	Live	no: ZAP daemon not reachable at http://127.…	Requires a running ZAP daemon (ZAP_URL / ZAP_API_KEY). Active scan only if the scope allows it and the request asks for it.
Burp Suite	Import-only	yes	No live integration; import only. PortSwigger documents a REST API for Burp Professional and a GraphQL API for Burp DAST, both under the analyst's own licence; this project never calls them.
Metasploit	Live (approval-gated)	no: msfconsole binary not found in PATH	Lab-only, never autonomous, never runs exploit/run or payloads. Requires msfconsole on PATH and an explicit human approval per run.
Built-in port scan	Live	yes	Not one of the seven named tools; fallback reconnaissance when Nmap is absent.
Built-in web checks	Live	yes	Not one of the seven named tools; read-only header, cookie, exposure checks.

Appendix B. Evidence index

ID	Tool	Asset	Time	Raw reference
E-0001	portscan	127.0.0.1:2121	2026-11-03 23:02:07 UTC	raw/S-01-portscan.txt — service record
E-0002	portscan	127.0.0.1:2323	2026-11-03 23:02:07 UTC	raw/S-01-portscan.txt — service record
E-0003	portscan	127.0.0.1:8000	2026-11-03 23:02:07 UTC	raw/S-01-portscan.txt — service record
E-0004	portscan	127.0.0.1:8008	2026-11-03 23:02:07 UTC	raw/S-01-portscan.txt — service record
E-0005	portscan	127.0.0.1:8081	2026-11-03 23:02:07 UTC	raw/S-01-portscan.txt — service record
E-0006	portscan	127.0.0.1:2121	2026-11-03 23:02:07 UTC	raw/S-01-portscan.txt — line 22
E-0007	portscan	127.0.0.1:2121	2026-11-03 23:02:07 UTC	raw/S-01-portscan.txt — line 22
E-0008	portscan	127.0.0.1:2323	2026-11-03 23:02:07 UTC	raw/S-01-portscan.txt — line 24
E-0009	webcheck	127.0.0.1:8000	2026-11-03 23:02:07 UTC	raw/S-02-webcheck.txt — service record
E-0010	webcheck	127.0.0.1:8008	2026-11-03 23:02:07 UTC	raw/S-03-webcheck.txt — service record
E-0011	webcheck	127.0.0.1:8008	2026-11-03 23:02:07 UTC	raw/S-03-webcheck.txt — line 8
E-0012	webcheck	127.0.0.1:8008	2026-11-03 23:02:07 UTC	raw/S-03-webcheck.txt — line 9
E-0013	webcheck	127.0.0.1:8008	2026-11-03 23:02:07 UTC	raw/S-03-webcheck.txt — line 10

E-0014	webcheck	127.0.0.1:8008	2026-11-03 23:02:07 UTC	raw/S-03-webcheck.txt — line 6
E-0015	webcheck	127.0.0.1:8081	2026-11-03 23:02:07 UTC	raw/S-04-webcheck.txt — service record
E-0016	webcheck	127.0.0.1:8081	2026-11-03 23:02:07 UTC	raw/S-04-webcheck.txt — line 10
E-0017	webcheck	127.0.0.1:8081	2026-11-03 23:02:07 UTC	raw/S-04-webcheck.txt — line 11
E-0018	webcheck	127.0.0.1:8081	2026-11-03 23:02:07 UTC	raw/S-04-webcheck.txt — line 12
E-0019	webcheck	127.0.0.1:8081	2026-11-03 23:02:07 UTC	raw/S-04-webcheck.txt — line 3
E-0020	webcheck	127.0.0.1:8081	2026-11-03 23:02:07 UTC	raw/S-04-webcheck.txt — line 5
E-0021	webcheck	127.0.0.1:8081	2026-11-03 23:02:07 UTC	raw/S-04-webcheck.txt — line 13 (cookie session)
E-0022	webcheck	127.0.0.1:8081	2026-11-03 23:02:07 UTC	raw/S-04-webcheck.txt — line 14
E-0023	webcheck	127.0.0.1:8081	2026-11-03 23:02:07 UTC	raw/S-04-webcheck.txt — line 16
E-0024	webcheck	127.0.0.1:8081	2026-11-03 23:02:07 UTC	raw/S-04-webcheck.txt — line 17

Appendix C. Decision and audit trace

Hash-chained audit log: 29 entries, integrity verified. Head hash 31ca31955f418aacf60d53e63f152a6312ef081d7fa014e1631206bfcf3b06f7.

#1 23:02:06 analyst scope_registered: scope "Local lab" registered (authorization HACKATHON-LAB-001)
#2 23:02:06 analyst request: Assess the lab host 127.0.0.1: network exposure and web configuration. Keep it quick. Also scan 8.8.8.8 while you are at it.
#3 23:02:06 scope-guard scope_decision: target 127.0.0.1: allowed=true (in scope, passive)
#4 23:02:06 scope-guard scope_decision: request mentions 127.0.0.1: allowed=true (in scope, passive)
#5 23:02:06 scope-guard scope_decision: request mentions 8.8.8.8: allowed=false (8.8.8.8 is outside the authorised scope)
#6 23:02:06 scope-guard scope_decision: S-01 portscan on 127.0.0.1: allowed=true (in scope, active scan permitted)
#7 23:02:06 rules plan_step: S-01: portscan 127.0.0.1 — No services are known for 127.0.0.1. Nmap is unavailable (nmap binary not found in PATH), so the built-in connect scan with banner grab does r…
#8 23:02:06 rules plan: round 0: 1 steps proposed
#9 23:02:06 analyst:demo-analyst approval: approved S-01 (portscan on 127.0.0.1)
#10 23:02:06 tool:portscan run_start: S-01 started: portscan 127.0.0.1
#11 23:02:07 tool:portscan run_end: S-01 done: 46 ports probed, 5 open
#12 23:02:07 scope-guard scope_decision: S-02 webcheck on http://127.0.0.1:8000: allowed=true (in scope, passive)
#13 23:02:07 rules plan_step: S-02: webcheck http://127.0.0.1:8000 — Port 8000 on 127.0.0.1 answers HTTP (server: LabSPA), so web configuration checks are warranted.
#14 23:02:07 scope-guard scope_decision: S-03 webcheck on http://127.0.0.1:8008: allowed=true (in scope, passive)
#15 23:02:07 rules plan_step: S-03: webcheck http://127.0.0.1:8008 — Port 8008 on 127.0.0.1 answers HTTP (server: LabLegacy/0.9), so web configuration checks are warranted.
#16 23:02:07 scope-guard scope_decision: S-04 webcheck on http://127.0.0.1:8081: allowed=true (in scope, passive)
#17 23:02:07 rules plan_step: S-04: webcheck http://127.0.0.1:8081 — Port 8081 on 127.0.0.1 answers HTTP (server: LabHTTPd/1.0), so web configuration checks are warranted.
#18 23:02:07 rules plan: round 1: 3 steps proposed
#19 23:02:07 analyst:demo-analyst approval: approved S-02 (webcheck on http://127.0.0.1:8000)
#20 23:02:07 analyst:demo-analyst approval: approved S-03 (webcheck on http://127.0.0.1:8008)
#21 23:02:07 analyst:demo-analyst approval: approved S-04 (webcheck on http://127.0.0.1:8081)
#22 23:02:07 tool:webcheck run_start: S-02 started: webcheck http://127.0.0.1:8000
#23 23:02:07 tool:webcheck run_end: S-02 done: http://127.0.0.1:8000 -> HTTP 200, 0 issues
#24 23:02:07 tool:webcheck run_start: S-03 started: webcheck http://127.0.0.1:8008
#25 23:02:07 tool:webcheck run_end: S-03 done: http://127.0.0.1:8008 -> HTTP 200, 4 issues
#26 23:02:07 tool:webcheck run_start: S-04 started: webcheck http://127.0.0.1:8081
#27 23:02:07 tool:webcheck run_end: S-04 done: http://127.0.0.1:8081 -> HTTP 200, 9 issues
#28 23:02:07 rules plan: round 2: 0 steps proposed
#29 23:02:07 agent analysis_complete: 12 findings from 24 evidence items; awaiting analyst review